

Authority for Personal Data
P.O. Box 93374, 2509 AJ The Hague
Hoge Nieuwstraat 8, 2514 EL The Hague
T 070 8888 500 - F 088 0712 140
autoriteitpersoonsgegevens.nl
The Minister of Health, Welfare and Sport
P.O. Box 20350
2500 EJ THE HAGUE
Date

November 28, 2023

Our reference

z2023-02938

Your letter dated

July 14, 2023

Contact person

Your reference

3636519-1051026-DICIO

Subject

Advice on the draft bill DIAZ

Dear Mr. Kuipers,

In a letter dated July 14, 2023, the Authority for Personal Data (AP) was consulted pursuant to the provisions of Article 36, fourth paragraph, of the General Data Protection Regulation (GDPR) regarding the draft amendment to the Act on Additional Provisions for the Processing of Personal Data in Healthcare (Wabvpz) in relation to digital identification and authentication in healthcare (hereinafter: the draft).

The AP objects to the draft concerning the proposed Articles 14 and 15 and advises that the procedure should not continue unless the objection is removed (paragraph 1). Furthermore, the draft gives the AP reason to make several comments (paragraphs 2 to 5).

Main points of the advice

- The draft aims to encourage healthcare providers and healthcare workers to use login tools that meet a high level of reliability for access to electronic exchange systems and healthcare information systems. Although the AP welcomes this initiative, it believes that stronger government action is warranted.
- Firstly, because in practice there are still insufficient suitable login tools available at a high level of reliability. The AP is not convinced that these will emerge voluntarily from the field in the near future. Secondly, because the draft does not mandate the use of login tools at a high level of reliability, except for access to SBV-Z.¹

¹ With SBV-Z (Sectoral Messaging Provision in Healthcare), registered individuals can request or verify the BSN of a patient from the Basic Registration of Persons (BRP). See Article 3 of the Act on General Provisions for the Citizen Service Number (Wabb) and sbv-z.nl/about-us.

Date

November 28, 2023

Our reference

z2023-02938

2/9

- The AP advises to include a specific deadline in the draft from which care providers and care staff are required to use approved login means with a high level of reliability to gain access to electronic exchange systems and care information systems. As long as these login means are not suitable or

available in practice, it is, in the opinion of the AP, the responsibility of the minister to ensure that there is at least one login means that meets the high level of reliability and is suitable for practical use.

- Additionally, the AP has comments on measures that increase usability but at the same time may lower the security level (advice point 2.1), on the risks associated with the use of private phones (advice point 2.2), on allowing care staff access to the register (advice point 3), on access to other services than electronic exchange systems and care information systems (advice point 4.1), on the linking of HR systems (advice point 4.2), on the excessive emphasis on data exchange (5.1), and on the expansion of the powers of the IGJ (advice point 5.2).

Scope of the draft

Currently, there are separate UZI registers for care providers, indication bodies, and health insurers in which they can be registered upon request. Once registered, they can apply for a UZI card or a UZI server certificate (together: UZI means) that allows access to SBV-Z. Additionally, with the UZI means, access can be obtained to the National Switch Point (LSP) and several services such as the National Implant Register and the communication node VECOZO. The possession of a UZI card alone is not sufficient to gain access to care information without further authorization. Moreover, simply offering the card is not enough; a PIN code must also be entered.

Primarily, the explanatory memorandum mentions three problems regarding current practice. First, there is currently no basis for the use of the UZI registers and UZI means for services other than SBV-Z. Second, practice experiences various problems.

2 Unique Healthcare Provider Identification Register; The UZI register is managed by the CIBG, a part of the Ministry of VWS.

3 Article 14, first paragraph, Wabvpz.

4 The UZI card is issued to individuals and contains a chip on which the healthcare identity of the registrant is physically printed. The UZI card is read with a card reader. The data on the chip are, according to the explanatory memorandum (MvT) p. 13, the so-called UZI attributes: who are you = unique healthcare identification number or UZI number, where do you work = unique registration subscriber number or URA number, what are your powers = role code indicating what powers a healthcare professional has.

5 The UZI server certificate is issued by the CIBG to systems and concerns a computer file that meets the standards of the Public Key Infrastructure for the government (PKI-o). With the certificate, a website, application, or server can demonstrate that it belongs to an organization registered in a UZI register; See also: logius.nl/domeinen/toegang/pkioverheid/hoe-werkt-het.

6 Article 15, third paragraph, Wabb.

7 See: bronnen.zorggegevens.nl/Bron?naam=Unieke-Zorgverlener-Identificatie-Register. This also includes the Secure Registration of Special Assets, the portal for Care Providers to Enter Declarations, and the National Contact Point for e-Health.

8 Authentication concerns the question of who someone is. Authorization concerns the question of what information someone is allowed to access. See also:

uziregister.nl/uzi-pas/waarvoor-heeft-u-een-uzi-pas-nodig/authenticatie and MvT p. 11.

9 This is evident from inquiries made with the ministry.

Date

November 28, 2023

Our reference

z2023-02938

3/9

with the UZI card,¹⁰ and thirdly, other login methods often do not meet the highest reliability level¹¹ of the eIDAS regulation¹² while this is required according to Article 5, first paragraph, under f, GDPR.¹³ The concept aims to resolve these issues as follows:

1 With the new login methods, registered individuals can gain access to electronic exchange systems and healthcare information systems in addition to SBV-Z.¹⁴ This applies only to healthcare providers

and healthcare staff, and thus not to health insurers and assessment bodies.¹⁶

2 With the concept, the CIBG will stop issuing UZI means,¹⁷ and in addition to physical cards and server certificates, other login methods can now also be used, provided that the Minister of VWS grants approval for this.¹⁸ The phasing out of UZI means will begin in 2025, allowing the healthcare sector until at least 2028 to transition to a new means.¹⁹

3 A condition for this is that the means, and if applicable, the linking of this means to a registered individual, meets the high reliability level.²⁰ That a login method meets the high reliability level can be demonstrated by providing evidence.²¹ It is intended that at least three different pieces of evidence will be designated by AMvB that can lead to approval:²²

- Public and private, Dutch and foreign, identification means²³ that are recognized under the Wdo.²⁴

10 The mentioned issues include costs, the risk of lending, unsuitability for use on mobile devices, and the fact that a new card must be created each time there is a change in the employer-employee relationship or profession.

11 Article 8, second paragraph, eIDAS describes three reliability levels for systems of electronic identification, which provide (1) limited, (2) substantial, or (3) higher levels of trust in a person's stated or claimed identity. For each reliability level, there are minimum technical specifications and procedures based on Article 8, third paragraph, eIDAS in conjunction with Article 1 and Annex of Implementing Regulation eIDAS (EU) No. 2015/1502. See also:

<https://www.avghelpdeskzorg.nl/onderwerpen/eidas>.

12 Regulation (EU) No. 910/2014 of the European Parliament and of the Council of July 23, 2014, on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC. National rules regarding this are established in the Digital Government Act (Wdo).

13 Explanatory Memorandum p. 16.

14 Proposed Article 14a, first paragraph, Wabvpz.

15 Proposed Article 14a, second paragraph, Wabvpz; Proposed Article 14a, fourth paragraph, under a, Wabvpz.

16 Explanatory Memorandum p. 10.

17 This means that CIBG is no longer a Trusted Service Provider (TSP) under the PKI-o system. This task will be taken over by other TSPs that must meet the requirements to issue PKI-o means, see Explanatory Memorandum p. 15. Regarding the issuance of healthcare-specific means, both the provider of a means and the healthcare provider or umbrella organization that issues that means (which can also be the provider itself) must be certified under NEN 7518. See Explanatory Memorandum p. 15.

18 Proposed Article 15, first paragraph, Wabvpz; In practice, the CIBG will be tasked with granting approval of the login means, as indicated on p. 22 of the Explanatory Memorandum.

19 Explanatory Memorandum p. 23.

20 Proposed Article 15, first paragraph, Wabvpz.

21 Explanatory Memorandum p. 12.

22 Proposed Article 15, second paragraph, under a-e, Wabvpz.

23 Article 1 Wdo: '[An] electronic means that contains personal identification data and is used for the authentication of a natural person, legal entity, or business seeking access to electronic services.'

24 Article 9 Wdo, which aims to allow identification means and services, has not yet come into force. DigiD is an example of a public identification means that is recognized under the Wdo.

Date

November 28, 2023

Our reference

z2023-02938

4/9

- Certification of care-specific means²⁵ under NEN 7518²⁶.²⁷

- PKI-o-certification (continuation of the UZI server certificates).

In addition, instead of separate UZI registers for care providers, indication bodies, and health insurers, a single register is now established.²⁸ A new category 'care worker'²⁹ will also be added to that register. Care workers can easily register in the UZI register at the CIBG. The care provider then verifies whether the care worker is employed by them and whether they need access to SBV-Z or other systems used by the care provider. If the care worker is no longer employed by the care provider, they remain registered in the UZI register but lose access to those systems.³⁰ When linking a care-specific login means to a registrant, the care provider processes the BSN of the registrant.³¹

Advice

1. Stronger government action required

Pursuant to Article 32 GDPR, data controllers and processors are required to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. Since health data is considered special personal data³², stricter requirements are imposed on the security of that data than on other personal data. In cases involving data subject to the medical confidentiality of the healthcare provider, the AP has regularly indicated in the context of patient authentication for access to patient portals that the 'highest level of reliability' is required.³³ In the terminology of the eIDAS Regulation, a login means must meet the reliability level 'high'.

²⁵ According to the explanatory memorandum, p. 13, this concerns electronic means for identification and authentication issued under the responsibility of a care provider to its care workers, such as a hospital pass (also known as a staff pass) or a digital wallet. Digital wallets are defined in the explanatory memorandum as 'login means that store the care identity from the UZI register in the 'wallet' and thus do not go through the UZI register with every login', explanatory memorandum, p. 27. ²⁶ The NEN 7518 (Identification & Authentication) is still under development. Expected publication at the end of 2023, see gegevensuitwisselingindezorg.nl/actueel/nieuws/2023/05/08/overzicht-ontwikkeling-nen-normen-wegiz.

²⁷ 'To be eligible for approval, the certificate of a care-specific means must be issued by a [certification body] accredited by the [Accreditation Council]', explanatory memorandum, p. 13.

²⁸ Proposed Article 14, third paragraph, under a-d, Wabvpz.

²⁹ Defined in the proposed Article 1 Wabvpz, under a yet to be determined sub-item number, as follows: 'anyone who performs or will perform activities for a care provider and consults client data using an approved login means'. Under 'login means' is understood, based on the same provision: '[an] electronic means for identification and authentication for the purpose of electronic data exchange in healthcare'.

³⁰ Explanatory memorandum, p. 11-12.

³¹ Proposed Article 14a, third paragraph, Wabvpz. For the issuance of a means recognized under the Wdo, this basis already exists under Article 16 Wdo; The legal basis for processing the BSN applies only to care providers. It is provided that other issuers of care-specific means will enter into a contract with care providers. This makes care providers data controllers and issuers, unlike care providers themselves, processors. See explanatory memorandum, p. 20.

³² Article 9 of the GDPR.

³³ Letter from the AP to the Ministry of VWS dated October 4, 2018, regarding patient authentication (z2018-17577) and Letter from the AP to the NVZ Dutch Hospitals Association dated October 7, 2016.

Date

November 28, 2023

Our reference

z2023-02938

5/9

The draft also emphasizes the use of a high level of reliability for the authentication of healthcare providers and healthcare staff.³⁴ The Dutch Data Protection Authority (AP) endorses the importance of this and strongly supports the government's initiative to guide the sector towards that goal.

For the sake of completeness, the AP notes that the use of a login credential with a high level of

reliability does not, in itself, mean that an organization has taken all the necessary appropriate technical and organizational measures. However, the use of such a login credential can be part of the measures that need to be implemented. The AP therefore emphasizes that, in addition to the requirements set by the eIDAS Regulation for a high level of reliability, there may also be other measures that data controllers and processors must take under Article 32 of the General Data Protection Regulation (GDPR).

The AP states that it is primarily the responsibility of the data controller to take appropriate technical and organizational measures to meet the required level of security under Article 32, paragraph 1, of the GDPR. However, the explanatory memorandum indicates that the healthcare sector still uses "many different login methods that often do not meet the required high level of reliability."³⁵ This provides sufficient reason to conclude that stronger government action is warranted. In the opinion of the AP, the current proposals fall short in this regard.

This is fundamentally related to the fact that, as indicated by additional information provided by the ministry to the AP, there are still insufficient suitable login credentials available at a high level of reliability in practice, and it does not appear that such credentials will be available in the near future. The sector has been under the obligation for years to use login credentials that meet the highest level of reliability but has, as it appears, failed to do so adequately. This draft does not change that; healthcare providers are still allowed to choose whether or not to use an approved login credential, and the UZI credentials that do meet the high level of reliability will also be phased out. Thus, the healthcare sector will lose an important login credential that, although not ideal, works, is secure, and is currently the standard for access to the LSP, the National Implant Register, and VECOZO. Whether and when a suitable login credential will replace it remains a significant question mark. The AP considers this undesirable.

Furthermore, in the AP's opinion, the draft is too noncommittal. The approval of login credentials is not made mandatory, except for access to SBV-Z. However, inquiries with the ministry reveal that access to SBV-Z is often obtained via server certificates, not by logging in with, for example, a card or wallet. There is a risk that the draft will become an empty shell. Additionally, the costs that healthcare providers must incur to certify, adjust, or acquire new login credentials make it unattractive for them to take that step. This is especially true for medium-sized and small healthcare providers.

Given the seriousness of the current practice and the importance of reliable authentication for access to health data, the AP deems it necessary for the minister to take further measures to

34 Explanatory memorandum p. 8.

35 Explanatory memorandum p. 8.

Date

November 28, 2023

Our reference

z2023-02938

6/9

to ensure that the healthcare sector transitions to the use of login tools with a high level of reliability within a reasonable timeframe. Firstly, it is important that a concrete deadline is included in the law, after which the sector is required to use approved login tools with a high level of reliability. If such login tools are not available, it is, in the opinion of the AP, the minister's responsibility to ensure that at the time of the entry into force of the obligation, there is at least one login tool that meets the required level of reliability and is suitable for practical use. For example, this could be achieved by assigning the development of such a tool to the CIBG, by maintaining the production of the current UZI tools, or by engaging a private party to take on that task.

The AP advises that the draft includes a concrete deadline from which healthcare providers and healthcare workers are required to use approved login tools with a high level of reliability to access electronic exchange systems and healthcare information systems. As long as those login tools are not

suitable or available in practice, it is, in the opinion of the AP, the minister's responsibility to ensure that there is at least one login tool that meets the high level of reliability and is suitable for practical use.

2. Counterproductive measures

2.1 Circumvention of higher reliability level

Logging in with stronger authentication is estimated by the ministry to take a few seconds longer. To compensate for this, the ministry proposes that authentication only needs to occur once a day, and can also be requested outside of the healthcare process. Additionally, it is suggested to reduce the frequency of logging into various healthcare applications.³⁶

The AP warns of the security risks that such measures may entail. If logging in with a high level of reliability only needs to occur once a day, it remains possible to give that tool to someone else during the day. That other person would then apparently not need to provide a username, password, or anything similar.

The AP advises removing passages from the MvT that may suggest that secure login could be circumvented for the sake of user convenience.

2.2 Use of private phone

Registered individuals can choose, in addition to a card, for a digital wallet on a smartphone or tablet. If a work phone is used for this purpose, various security measures may already be in place. However, inquiries with the ministry reveal that a private phone can also be used. This need not be a problem, provided that the correct guidelines are followed to mitigate the risks that may arise from its use. However, monitoring compliance with those guidelines may prove more difficult than with a work phone, as an employer cannot simply monitor which other apps are being used.

36 MvT p. 24.

Date

November 28, 2023

Our reference

z2023-02938

7/9

an employee installs on their phone. If one employee installs malware on their phone, which regularly happens with personal phones,³⁷ this could already lead to a breach of the care system.

The AP advises in the MvT to also clarify the risks associated with the use of mobile devices and how those risks can be mitigated. According to the AP, these risks and the security measures against them should also be taken into account when developing and approving new login methods.

3. Registration of Care Workers

In addition to care providers, indication bodies, and health insurers, based on the new Article 14, first paragraph, introductory clause, of the draft, care workers can now also register in the UZI register. This group of natural persons is broader than the group that falls under the definition of care providers in Article 1 of the Act on Quality, Complaints, and Disputes in Healthcare (Wkkgz): "an institution or a solo-working care provider." The new definition of care workers includes not only care providers but also administrative staff, students, interns, or supervisors. In short, everyone who works or wants to work in the healthcare sector. Inquiry with the ministry reveals that there is no verification of this: "For natural persons (care workers, not being care providers), there are no grounds for refusal. A revocation of a registration in the register is [however] possible." The consequence of this is that there are no limits on who can register in the UZI register. Even though registration without authorization from an affiliated institution is in principle useless, it may open a door for abuse. This can be prevented by requiring that someone must demonstrate that they are working in the healthcare sector or will be doing so in the foreseeable future. For example, by requiring that someone provides an email address with a domain name of an institution affiliated with the register.

The AP advises that the register should be structured so that only natural persons who can

demonstrably show they are working in the healthcare sector, or will be doing so in the foreseeable future, can be registered.

4. Affiliated Services

4.1 Services other than EUS or healthcare information systems

The draft indicates that registrants with an approved login method can gain access to SBV-Z, electronic exchange systems, and healthcare information systems.³⁸ However, considering what is stated on p. 2 of this advice and footnote 7, there are also other services that can be logged into with an approved login method. One example is the National Implant Register. This register is maintained by the Minister of VWS and is intended for the Health and Youth Care Inspectorate (IGJ) to inform care providers about problems with a particular implant following a signal regarding a safety risk associated with that implant.³⁹ Thus, this register does not fall under

37 See e.g.: Police and Fraud Helpdesk busy with Android malware: 'This is something new, something different' (nos.nl) and Thousands of Dutch people have malware on their mobile after false SMS about a package (nos.nl).

38 Article 14, first paragraph under a and b and Article 14a, second paragraph.

39 Factsheet 'National Implant Register for Care Providers and -Providers' from the Ministry of VWS. Date

November 28, 2023

Our reference

z2023-02938

8/9

the definition in the Wabvpz of an electronic exchange system, for which the exchange of care providers to other care providers is required, nor under that of a care information system.

The AP advises to include an additional legal basis for the use of the new login methods for the categories of services that are currently excluded.

4.2 HR Systems

According to the MvT, "it is made possible to establish a connection with an HR system for automated registration in the register."⁴⁰ The background of this, as revealed by inquiries with the ministry, is that large healthcare institutions with many healthcare employees will spend a lot of time manually reporting initial registrations and changes. With a connection between the care provider's HR system and the UZI register, entries and exits will be immediately reported, making unauthorized access more difficult.

The AP advises that this explanation should also be included in the MvT. Additionally, the AP recommends addressing the security risks that may be associated with such a connection, and the requirements that such HR systems must meet.

5. Other

5.1 Excessive Emphasis on Data Exchange

In Article 14, first paragraph, under b of the draft, 'electronic data exchange' is mentioned. Also in the MvT, the emphasis is often on the exchange of data,⁴¹ while it equally concerns, perhaps even more often, access to one's own care information systems.

The AP advises to amend Article 14, first paragraph, under b, of the draft so that, in accordance with Article 14a, second paragraph, of the draft, it not only refers to 'electronic data exchange in healthcare' but also to 'access to care information systems'.

5.2 Expansion of IGJ Powers

In the draft, the new Articles 14 and 15 Wabvpz are categorized under the scope of the supervisory and enforcement powers assigned to the IGJ in the legislative proposal for the Data Processing Collection Act VWS II. The AP has advised in its opinion on that earlier legislative proposal to better substantiate why the current instruments of the AP and the IGJ are not sufficient to ensure the

enforceability of the Wabvpz.⁴²

The AP advises to take into account the implementation of the earlier advice from the AP in this draft.

40 MvT p. 25.

41 See several examples on MvT p. 1 and p. 2.

42 AP advice of October 17, 2023, on the 'Data Processing Collection Act VWS II' (z2023-00615), section 13.

Date

November 28, 2023

Our reference

z2023-02938

9/9

Workload AP

The AP notes that the draft is not expected to require additional effort from the AP.

Disclosure

This advice will be published on the AP's website within two weeks.

Yours sincerely,

Authority Personal Data,

Aleid Wolfsen

Chairman